

## Matriz de Evaluación PRAGMATIC de Métricas ISO 27001

Escala por criterio: 1 = muy bajo, 5 = muy alto.

La puntuación global puede ser la media simple o ponderada de los nueve criterios. [web:44][web:49]  
[web:52]

### 1. Leyenda de criterios

- P – Predictivo
- R – Relevante
- A – Accionable
- G – Genuino
- M – Significativo
- A2 – Preciso (Accurate)
- T – Oportuno (Timely)
- I – Independiente
- C – Rentable (Cheap)

## 2. Tabla de métricas principales

### 2.1 Madurez y desempeño global

| ID métrica   | Descripción                               | P | R | A | G | M | A2 | T | I | C | Comentario breve                                                                     |
|--------------|-------------------------------------------|---|---|---|---|---|----|---|---|---|--------------------------------------------------------------------------------------|
| M-M AD-SCORE | Puntuación global de madurez SGSI (0-100) | 3 | 5 | 4 | 4 | 5 | 4  | 3 | 3 | 3 | Buen indicador de síntesis; predictivo moderado, requiere base de evaluación sólida. |
| M-M AD-DELTA | Variancia anual de la madurez             | 3 | 4 | 4 | 4 | 4 | 4  | 3 | 3 | 3 | Útil para ver tendencia; más accionable que el valor estático.                       |

## 2.2 Gestión de riesgos

| ID métrica            | Descripción                                         | P | R | A | G | M | A2 | T | I | C | Comentario                                                                  |
|-----------------------|-----------------------------------------------------|---|---|---|---|---|----|---|---|---|-----------------------------------------------------------------------------|
| <b>M-RISK-ASSETS</b>  | % activos críticos con análisis de riesgos vigentes | 4 | 5 | 4 | 4 | 4 | 4  | 4 | 3 | 3 | Buen predictor de sorpresas desagradables; relativamente barato.            |
| <b>M-RISK-TREATED</b> | % riesgos tratados dentro del plazo                 | 4 | 5 | 5 | 4 | 4 | 4  | 4 | 3 | 3 | Muy accionable: su variación desencadena acciones de remediación.           |
| <b>M-RISK-OVERAPP</b> | % riesgos residuales sobre el apetito               | 5 | 5 | 5 | 4 | 5 | 4  | 3 | 3 | 3 | Métrica clave de alineamiento riesgo-negocio; fuerte impacto en decisiones. |



## 2.3 Controles técnicos, vulnerabilidades, exposición

| ID métrica      | Descripción                                                  | P | R | A | G | M | A2 | T | I | C | Comentario                                                                       |
|-----------------|--------------------------------------------------------------|---|---|---|---|---|----|---|---|---|----------------------------------------------------------------------------------|
| M-TECH-CRIT-MTR | Tiempo medio de corrección de vulnerabilidades críticas      | 5 | 5 | 5 | 4 | 4 | 4  | 4 | 3 | 3 | Altamente predictivo del riesgo de explotación; accionable.                      |
| M-TECH-SUPP-ORT | % sistemas en versiones soportadas                           | 4 | 5 | 4 | 4 | 4 | 4  | 3 | 3 | 3 | Indicador estructural de "higiene"; más lento de cambiar pero relevante.         |
| M-TECH-EXPOSED  | % activos expuestos a internet con vulnerabilidades críticas | 5 | 5 | 5 | 4 | 5 | 4  | 4 | 3 | 3 | Uno de los indicadores más críticos; gran valor predictivo de incidentes graves. |



## 2.4 Incidentes, SOC, respuesta

| ID métrica         | Descripción                             | P | R | A | G | M | A2 | T | I | C | Comentario                                                         |
|--------------------|-----------------------------------------|---|---|---|---|---|----|---|---|---|--------------------------------------------------------------------|
| M-IN<br>C-MT<br>TD | Tiempo medio de detección de incidentes | 5 | 5 | 5 | 4 | 4 | 4  | 4 | 3 | 3 | Muy predictivo del impacto: cuanto antes se ve, menos duele.       |
| M-IN<br>C-MT<br>TR | Tiempo medio de respuesta/resolución    | 4 | 5 | 5 | 4 | 4 | 4  | 4 | 3 | 3 | Acción directa sobre capacidad de respuesta; clave en resiliencia. |
| M-IN<br>C-SLA      | % incidentes resueltos dentro de SLA    | 4 | 5 | 4 | 4 | 4 | 4  | 3 | 3 | 3 | Métrica de desempeño del SOC / equipos de respuesta.               |



|                              |                                                   |   |   |   |   |   |   |   |   |   |                                                                     |
|------------------------------|---------------------------------------------------|---|---|---|---|---|---|---|---|---|---------------------------------------------------------------------|
| <b>M-IN<br/>C-SEV</b>        | Severidad media ponderada de incidentes           | 4 | 5 | 4 | 4 | 4 | 4 | 3 | 3 | 3 | Captura la “gravidad” agregada; requiere clasificación consistente. |
| <b>M-IN<br/>C-REC<br/>UR</b> | Tasa de reincidencia de incidentes por causa raíz | 4 | 5 | 5 | 4 | 4 | 4 | 3 | 3 | 3 | Excelente para saber si aprendemos o repetimos los mismos errores.  |

## 2.5 Concienciación y comportamiento

| ID métrica                   | Descripción                                            | P | R | A | G | M | A2 | T | I | C | Comentario                                                             |
|------------------------------|--------------------------------------------------------|---|---|---|---|---|----|---|---|---|------------------------------------------------------------------------|
| M-A<br>WAR<br>E-COVER        | % empleados con formación de seguridad completada      | 3 | 4 | 3 | 4 | 3 | 4  | 3 | 3 | 3 | Métrica básica ; valor limitado si no se mide eficacia.                |
| M-A<br>WAR<br>E-PHISH-CLICK  | % clic en simulaciones de phishing                     | 5 | 5 | 5 | 4 | 4 | 4  | 4 | 3 | 3 | Muy predictivo de riesgo por ingeniería social ; altamente accionable. |
| M-A<br>WAR<br>E-PHISH-REPORT | Nº de reportes legítimos de phishing por 100 empleados | 4 | 4 | 4 | 4 | 4 | 4  | 3 | 3 | 3 | Mide cultura de reporte; algo más caro pero de alto valor cualitativo. |

## 2.6 Continuidad y resiliencia

| ID métrica                 | Descripción                                         | P | R | A | G | M | A2 | T | I | C | Comentario                                               |
|----------------------------|-----------------------------------------------------|---|---|---|---|---|----|---|---|---|----------------------------------------------------------|
| M-RE<br>S-BCP-<br>COVER    | % procesos críticos con BCP/DRP actualizados        | 4 | 5 | 4 | 4 | 4 | 4  | 3 | 3 | 3 | Indicador estructural de preparación.                    |
| M-RE<br>S-TES<br>T-COVER   | % pruebas de continuidad realizadas vs planificadas | 4 | 5 | 4 | 4 | 4 | 4  | 3 | 3 | 3 | Indicador disciplina de prueba; accionable cuando baja.  |
| M-RE<br>S-RTO-<br>MEE<br>T | % pruebas que cumplen RTO/RPO                       | 5 | 5 | 5 | 4 | 4 | 4  | 3 | 3 | 3 | Métrica crítica de resiliencia real, no solo documental. |

## 2.7 Proveedores y terceros

| ID métrica                | Descripción                                        | P | R | A | G | M | A2 | T | I | C | Comentario                                                             |
|---------------------------|----------------------------------------------------|---|---|---|---|---|----|---|---|---|------------------------------------------------------------------------|
| M-SU<br>P-CRI<br>T-EVAL   | % proveedores críticos evaluados y aprobados       | 4 | 5 | 4 | 4 | 4 | 4  | 3 | 3 | 3 | Buen indicador de control de la cadena de suministro.                  |
| M-SU<br>P-SEC-<br>-CLAUSE | % proveedores con cláusulas de seguridad adecuadas | 3 | 4 | 3 | 4 | 3 | 4  | 2 | 3 | 3 | Más jurídico, menos predictivo, pero necesario.                        |
| M-SU<br>P-INC             | Nº incidentes atribuibles a terceros               | 4 | 5 | 4 | 4 | 4 | 4  | 3 | 3 | 3 | Métrica de resultado; combinada con las anteriores da visión completa. |

## 2.8 Regulación y entorno externo

| ID métrica               | Descripción                                      | P | R | A | G | M | A2 | T | I | C | Comentario                                                    |
|--------------------------|--------------------------------------------------|---|---|---|---|---|----|---|---|---|---------------------------------------------------------------|
| M-RE<br>G-NIS<br>2-ALIGN | Índice de alineamiento o percibido con NIS2      | 3 | 5 | 4 | 3 | 4 | 3  | 3 | 3 | 3 | Métrica compuesta, algo subjetiva; requiere criterios claros. |
| M-RE<br>G-BREACH         | Nº de brechas de datos y tiempos de notificación | 4 | 5 | 4 | 4 | 4 | 4  | 3 | 3 | 3 | Conecta directamente con obligaciones GDPR y supervisores.    |

## 2.9 Automatización, calidad de datos y gobierno

| ID métrica    | Descripción                                      | P | R | A | G | M | A2 | T | I | C | Comentario                                                                 |
|---------------|--------------------------------------------------|---|---|---|---|---|----|---|---|---|----------------------------------------------------------------------------|
| M-GOV-AUTO    | % datos de indicadores obtenidos automáticamente | 3 | 4 | 4 | 4 | 3 | 4  | 3 | 3 | 3 | Predice capacidad de escalar la medición y reducir errores manuales.       |
| M-GOV-DATQUAL | Índice de calidad percibida de los datos         | 3 | 4 | 4 | 3 | 4 | 3  | 3 | 3 | 3 | Algo subjetivo, pero útil como alerta temprana de problemas de fiabilidad. |

(Puedes adaptar las puntuaciones PRAGMATIC a tu contexto; aquí se proponen valores “por defecto” razonables basados en la literatura de métricas de seguridad y en la experiencia práctica.)